

reco

The State of Agent Security 2026



Table of Contents

02 Executive Summary: The Agent Era Is Here

03 Glossary

04 Setting the Stage: The Year the Agents Arrived

05 Our Findings

06 Finding 1 - Strong Governance, 414 Unsanctioned AI Tools per 1,000 Staff

06 Finding 2 - Four in Five AI Tools Answer to No One

07 Finding 3 - What 500 Agent Tools Can Do: Half Run Shell Commands

07 Finding 4 - Toxic Combinations: 62% Read and Ship Your Data

08 Finding 5 - A Critical Vulnerability Every Few Days: 525 in 18 Months

09 From Findings to Fixes

09 The Governance Paradox

09 The Oversight Gap

09 Powerful by Default

10 Toxic Combinations

10 The Vulnerability Flood

11 Leveraging Reco to Tackle Agent Security

11 Step 1: Build the Agent Inventory

12 Step 2: Map Identities and Permissions

12 Step 3: Govern Tools, Agents, and Context

13 Step 4: Classify Data and Identity Risk

14 Step 5: Detect Exposure and Prove Control

15 The Choice Ahead

Executive Summary:

The Agent Era Is Here

Something new is operating inside your environment: software that autonomously logs in, makes changes, and acts with the permissions of the people who deployed it. Almost nothing in your traditional security stack was built to watch it.

AI agents now read inboxes, file tickets, write code, and move records between applications under standing OAuth grants, and most arrived the way unsanctioned AI always has: one consent screen at a time, with no security review.

An attacker who gets into a chatbot sees whatever employees pasted into it, while one who gets into an agent inherits everything it was permitted to reach, at machine speed, under a non-human identity your organization created but never meets.

The unit of risk has moved from the application to the identity, yet most security programs still measure the application, and the target is moving: the tools agents run on barely existed eighteen months ago.

This report measures that shift, through **five primary findings**:

- 1 Most SaaS applications are authorized, yet small firms carry **414** unsanctioned AI tools per 1,000 employees.
- 2 **Four in five** AI tools run with no IT oversight, and that ungoverned share is where agents operate.
- 3 Of the 500 public MCP servers we examined, **half** can run shell commands on the host machine.
- 4 **62%** of published agent tools can read your data and ship it out in one package.
- 5 The agent and LLM-tooling ecosystem produced **525** vulnerabilities in eighteen months, at least **111** of them critical.

In order to measure both layers, we paired Reco telemetry across the SaaS estate with our own analysis of 500 published agent tools and the ecosystem's vulnerability disclosure record.

How we got these numbers

FINDING	WHERE IT COMES FROM	WHAT IT MEASURES
414 unsanctioned AI tools per 1,000 employees	Reco platform telemetry	AI tools seen without IT approval, normalized per 1,000 employees at small and mid-size firms
Four in five AI tools with no IT oversight	Reco platform telemetry	Share of the AI tools in our telemetry running without IT oversight
Half of 500 agent tools run shell commands	Our analysis of 500 published MCP servers (npm)	Servers whose shipped code can execute shell commands
62% read and ship your data	Our analysis of 500 published MCP servers (npm)	Servers holding file-read and network egress together
525 vulnerabilities, at least 111 critical	Public vulnerability record (NVD)	CVEs across agent and LLM-tooling keywords since January 2025 (critical = CVSS 9.0+)

One thread runs through all five: the controls that secured the application estate do not see the identity layer where agents now operate. The pages ahead lay out the year's record, the findings beneath it, and the priorities that follow from them.

Glossary

A quick reference for the terms that recur through this report:

TERM	DEFINITION
AI Agent	An autonomous or semi-autonomous AI system that takes actions across software under its own standing permissions: reading data, calling tools, and triggering other agents.
Unsanctioned AI	Any AI application or agent adopted by employees without IT or security approval.
Non-Human Identity (NHI)	A machine identity (an agent, service account, API key, or OAuth grant) that holds access to enterprise systems without a human logging in.
Model Context Protocol (MCP)	The dominant standard for connecting agents to data and tools. An MCP server is the code that exposes a capability to an agent.

TERM	DEFINITION
OAuth Grant	A scoped permission an application or agent receives to act against a system on a user's behalf, without ever handling the password.
Toxic Combination	A permission breakdown across two or more applications, bridged by an agent or OAuth grant, that no single application owner authorized as its own risk.
Tool Poisoning	Distributing a malicious capability through an agent marketplace so that any agent installing it inherits attacker-controlled behavior.

Setting the Stage:

The Year Agents Arrived

The tools that agents run on barely existed eighteen months ago. Of the 500 agent tools we examined, **96%** were first published in the past two years, and the current year has already produced nearly as many as the entire twelve months before it, with half the year still to go.

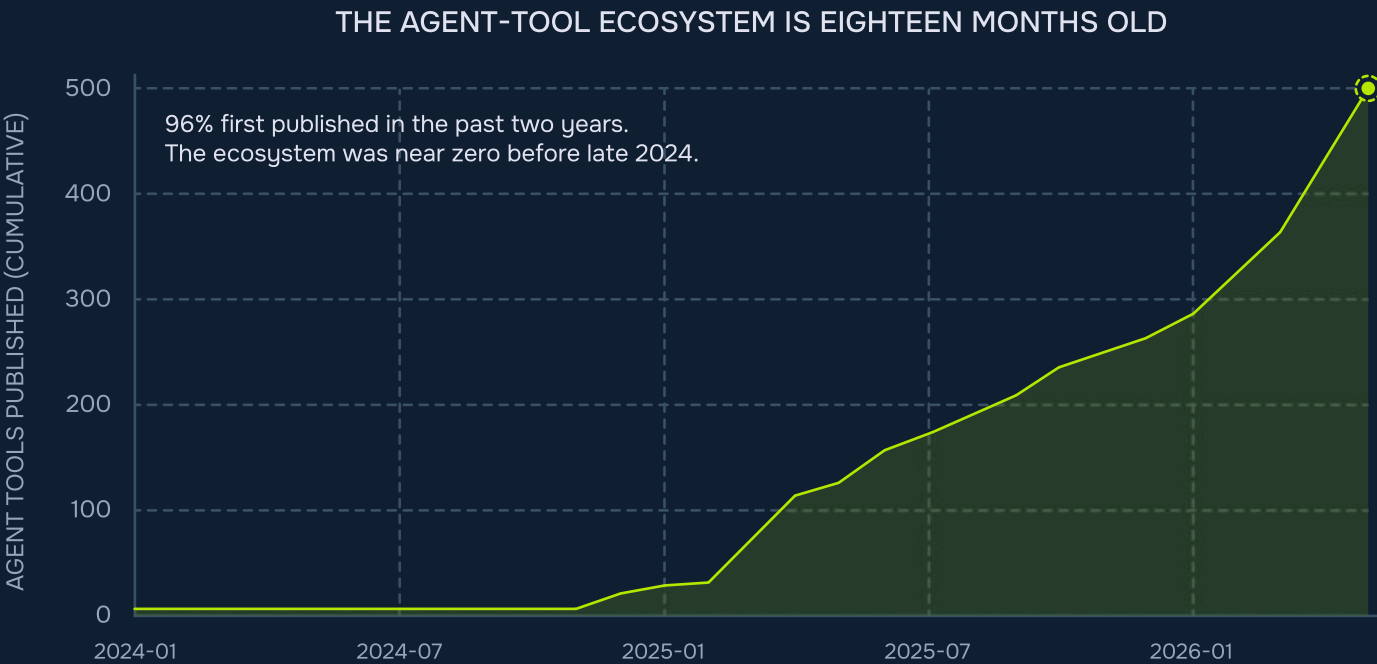


Figure 1: Agent tools published over time, 96% in the past two years.

An ecosystem this young has no settled controls around it, so a governance gap was always going to follow. The speed bought no safety either, because the same eighteen months turned agent security from a projection into a case file:

WHEN	WHAT HAPPENED	WHAT IT PROVED
Jan 2026	OpenClaw remote code execution (CVE-2026-25253)	One malicious webpage hijacks an autonomous agent
Feb 2026	Two command-injection vulnerabilities	Patch cycles lose to viral adoption
Feb 2026	ClawHub: 12% of skills malicious	Agent marketplaces are an unvetted supply chain
Feb 2026	21,639 instances exposed	Every exposed instance is a standing identity
Feb 2026	Moltbook: 1.5M agent tokens leaked	Agent tokens are wearable identities at scale
May 2026	Government MCP hardening guidance	Agent security became a government advisory

OpenClaw is a relevant **case study**. This open-source autonomous agent passed 135,000 GitHub stars within weeks. It runs shell commands, manages files, browses, and sends email from the messaging apps employees already use, and it reaches corporate SaaS through ordinary OAuth consent: Slack, calendars, drives. Then the findings landed from researchers across the community: the control interface could be hijacked from a single malicious webpage, even bound to localhost.

The skill marketplace ran **12%** malicious, and a poisoned skill inherits the agent's full reach. The adjacent Moltbook breach leaked 1.5 million agent tokens from a service running 770,000 agents. Adoption at that speed leaves no room for anyone to stop and threat-model.

OpenClaw will not be the last of its kind, because the pattern repeats: a capable framework goes viral, accumulates permissions across consumer and corporate systems, ships a marketplace, and draws attackers, faster than any review cycle runs.

Unsanctioned adoption once meant data leaking out to tools nobody approved, whereas an unsanctioned agent is an actor operating inside your environment. Industry bodies now publish dedicated agentic-security guidance, and government agencies have issued **hardening advice** for agent protocols. The argument about whether agents are a security problem is over. What remains is whether enterprise governance can keep pace, which is what our telemetry measures next.

Our Findings

The headline numbers flatter the enterprise at first glance, but read together they describe a security program defending the wrong layer.

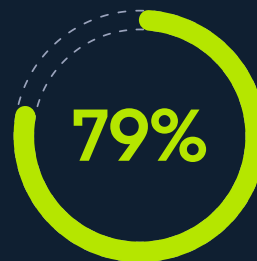


Finding 1 - Strong Governance, 414 Unsanctioned AI Tools per 1,000 Staff

In our telemetry, **79%** of SaaS applications are authorized. That is governance working at scale: cataloging, reviewing, and sanctioning the estate, and most programs would publish it. The same telemetry shows what the number hides. At small and mid-size companies, unsanctioned AI tools run at 414 per 1,000 employees, close to one for every two or three people on staff.

The two numbers measure different things, because authorization governs what arrives through procurement or surfaces in review, while unsanctioned AI arrives through a browser extension or an OAuth click. At a 40-person company, it's nobody's job to notice. That inverts the usual security assumption: the firms with the least capacity to vet an AI tool adopt them the fastest, and an unsanctioned agent at a 40-person company reaches the same payroll, customer, and source-code systems it would at a 40,000-person one.

GOVERNANCE IS STRONG AND
UNSANCTIONED AI IS RAMPANT AT ONCE



of SaaS applications are
authorized



unsanctioned AI tools per 1,000
employees at small companies

Figure 2: The governance paradox, 79% authorized vs 414 per 1,000.

Finding 2 - Four in Five AI Tools Answer to No One

Across the AI tools in our telemetry, **four in five** operate without IT oversight. The tools that do get oversight are the most visible ones, the major chatbots and the copilots inside sanctioned suites, so the ungoverned share is made of everything else.

FOUR IN FIVE AI TOOLS OPERATE
WITHOUT IT OVERSIGHT



The long tail is where agents live: automation frameworks, browser agents, and integration tools that hold standing permissions rather than waiting for prompts. Picture what hides there: a browser agent that summarizes the inbox, a workflow tool wired into the CRM, a coding assistant with repository access. Each is invisible to a program that counts sanctioned applications, and each acts on its own schedule, with its own credentials, long after the employee who connected it has moved teams or left.

Figure 3: Four in five AI tools operate without IT oversight.

Finding 3 - What 500 Agent Tools Can Do: Half Run Shell Commands

The first two findings measure adoption and posture; this one measures what the tools can actually do. Agents reach the rest of your stack through tools, and the dominant standard for those tools is the Model Context Protocol (MCP). We examined 500 such MCP servers, the kind installed with a single command. Despite the harmless-sounding name, an MCP server is code that runs on the host with the host's privileges.

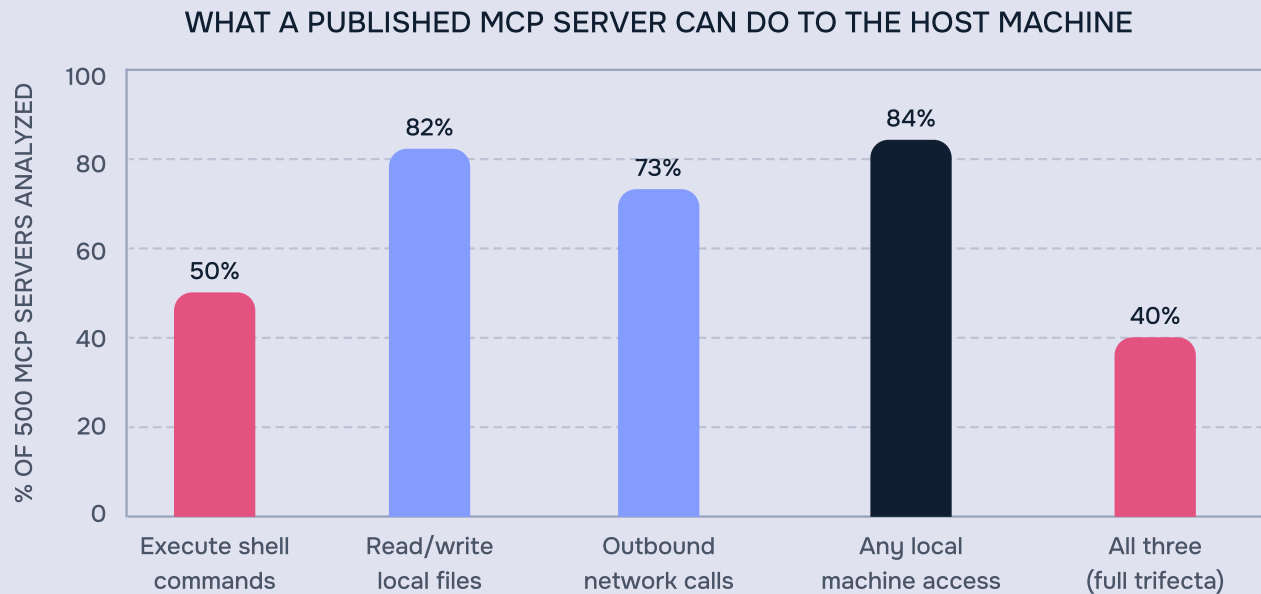


Figure 4: Capability census of 500 published MCP servers.

Exactly half can execute shell commands directly, which turns a prompt-injection trick into operating-system access, more than eight in ten can read or write local files, and roughly three-quarters can make outbound network calls. These are the tools agents are built to load, by the thousands, often through a marketplace with no review step. They rarely guard themselves either: just over a quarter expose a network endpoint rather than running locally, and half of those ship no authentication at all, a remotely reachable tool with host-level reach and no lock on the door.

Finding 4 - Toxic Combinations: 62% Read and Ship Your Data

Two in five of these tools combine all three at once, command execution, file access, and network egress in a single package. This creates the complete toolkit to find data, act on it, and move it off the machine. A prompt-injection payload chains the three into a complete attack. The agent reads a poisoned document, runs a command it was never meant to run, and ships the result outbound, all under credentials your organization issued, with no malware landing and no password stolen.

TOXIC COMBINATIONS: SAFE ALONE, DANGEROUS TOGETHER

Share of 500 published agent tools holding each pair of powers in a single package



Figure 5: The toxic combinations, 62%, 48%, and 40% of agent tools.

Security teams call those overlaps toxic combinations, access that is safe alone and dangerous together. The census lets us count them: **62%** of these tools can read local data and reach the internet in a single package (the exfiltration bridge, read it and ship it out), **48%** can run commands and touch files, and **40%** can run commands and reach the internet. The person who installed the tool approved one of those powers; nobody approved the pair. The risk compounds, because an agent rarely loads a single tool. Instead, a file-reading server from one author sitting beside a network server from another bridges two systems neither author scoped together, creating a toxic combination that a security team only sees if something maps the whole graph.

Finding 5 - A Critical Vulnerability Every Few Days: 525 in 18 Months

Capability and exposure describe what agent tools could do. Their vulnerability record describes what is already going wrong. The disclosure curve climbed slowly through 2024, then turned near-vertical, and most of the vulnerabilities on record have landed in just the last eighteen months, with half this year still to run.

AGENT-TOOLING VULNERABILITIES DISCLOSED OVER TIME

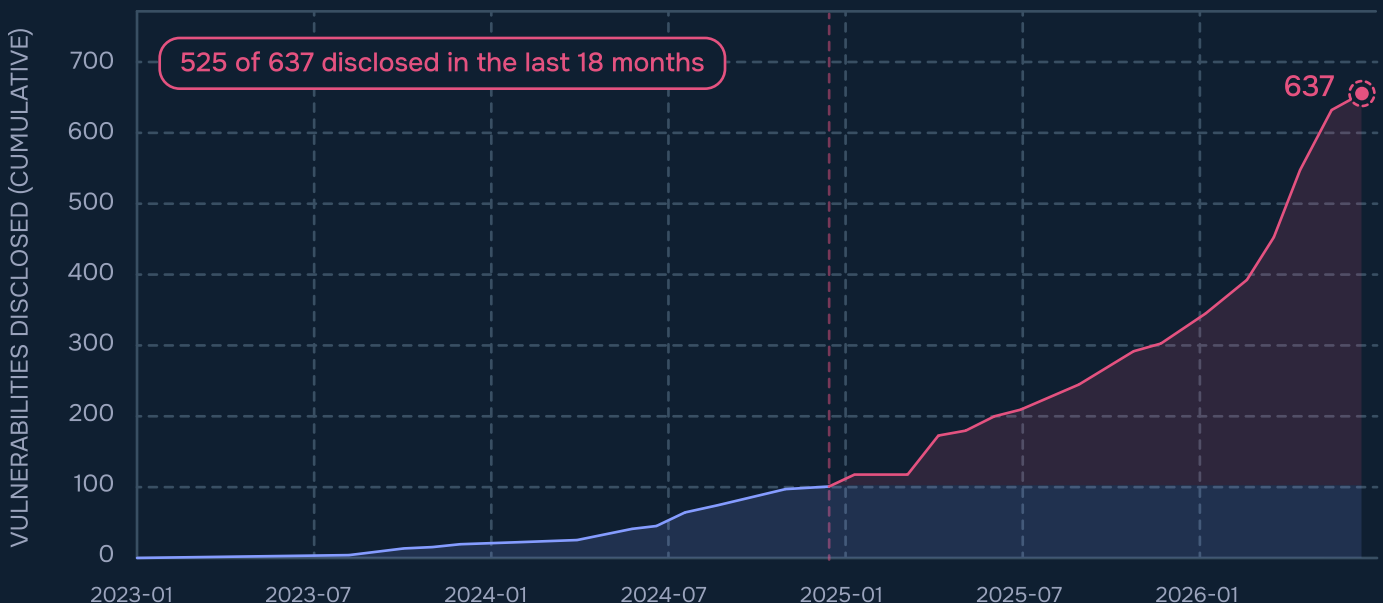
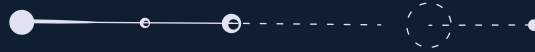


Figure 6: Agent-tooling vulnerabilities disclosed over time.

525 vulnerabilities have been disclosed in the past eighteen months, at least 111 of them critical, rated 9 or above on the Common Vulnerability Scoring System (CVSS). An ecosystem this young, shipping this fast, with this little review, produces vulnerabilities faster than any patch cycle absorbs them. The agent tool you installed last quarter is not the agent tool running today, and neither is its risk.



From Findings to Fixes

The five findings reduce to one conclusion: the current controls are pointed at the wrong layer. We authorize applications, but the risk lives in what identities are permitted to do. The response follows the same shape, finding by finding.

The Governance Paradox

With **79%** of SaaS authorized but **414** unsanctioned AI tools per 1,000 employees at the smallest firms, the program is winning on the layer it can see and blind on the one it cannot. Authorization counts what surfaces for review, and the AI estate grows through consent screens that never reach one.

The mitigation is **discovery**, because you cannot govern an identity you have never met. Inventory every agent, integration, and OAuth grant with a named owner, and track unsanctioned AI density alongside authorization rate. The second number is the one that should worry you.

The Oversight Gap

When **four in five** AI tools run with no IT oversight, nobody is watching the tools that act. Oversight lands on the household-name chatbots first and rarely reaches the long tail of automation tools holding standing permissions, so the gap is widest exactly where the autonomy is highest.

The watching has to start somewhere, and **time plus access** makes the shortlist. Audit any AI tool showing **60 or more days** of activity, beginning with the ones holding OAuth grants, while migration is still cheap.

Powerful by Default

Of the tools we examined, **half** can run commands and roughly **one in eight** is reachable with no authentication, so a tool's paperwork tells you nothing about what it can do on the host.

The review has to happen **at the grant**: which scopes a tool holds, who consented, and when each was last used. Revoke unused scopes by default, and treat marketplace tools as a supply chain, vetted before install, because no procurement step vets them for you.

Toxic Combinations

Because **62%** of these tools can read your data and ship it out in a single package, the danger rarely sits in any single permission. Whoever installed the tool accepted each power on its own, and the pair an attacker chains together is the one nobody ever accepted.

Hunt the **toxic combinations**. Map which tools pair data access with outbound egress, and which agents bridge two systems no single owner scoped together, then review the pairs the way you currently review individual permissions.

The Vulnerability Flood

At **525** vulnerabilities in eighteen months, new ones land faster than patch cycles absorb them. The only question during the next disclosure is "do we have it, and where," and most teams cannot answer it today.

Answering it requires a **live inventory** of which agent tools you actually run and having a kill switch behind each one. A kill switch gives you the ability to revoke an agent's access across every connected application in a single action. If revocation means logging into each app separately, you will learn it during the incident.

Together those mitigations form a continuous loop: discover, map, detect, revoke. Distilled into a standing checklist, an organization that can tick all ten has its agent layer under genuine control.

AREA	DESCRIPTION	PATCH	Y/N
Discovery	Agents, integrations, and OAuth grants exist that nobody catalogued	Discover the estate and give every grant a named owner	☐
Non-human identity	Agents run on the credentials of whoever installed them	Issue each agent its own non-human identity	☐
Access review	High-reach agents hold permissions nobody has reviewed	Review scopes on the 20 highest-reach agents each quarter	☐
Least privilege	Idle permissions accumulate and sit unrevoked	Revoke unused scopes by default	☐
Supply chain	Marketplace skills install with no review step	Gate skills behind review before they touch corporate data	☐
Oversight	Tools embed quietly for months without an audit	Alert on any AI tool active 60 or more days and route it to review	☐

AREA	DESCRIPTION	PATCH	Y/N
Threat detection	Nobody knows what normal looks like for an agent	Baseline each agent's behavior and alert on deviation	☐
Incident response	Revocation today means logging into each app separately	Build one-action revocation and test it in a live drill	☐
Toxic combinations	Tools pair data access with egress unnoticed	Map toxic combinations across application bridges	☐
Governance	Unsanctioned AI grows invisibly between reviews	Track density per 1,000 employees and report it quarterly	☐

Leveraging Reco to Tackle Agent Security

That loop is what the **Reco Platform** automates across an enterprise’s entire third-party agent and app ecosystem, in five steps.

Step 1: Build the Agent Inventory

Reco discovers AI applications, agents, browser extensions, OAuth grants, and connected integrations across the entire ecosystem, giving teams a live inventory of the agent layer that they can observe and govern. On deployment, it surfaces personal accounts and tools that never passed procurement through their OAuth and integration footprints across 260+ agents and applications.

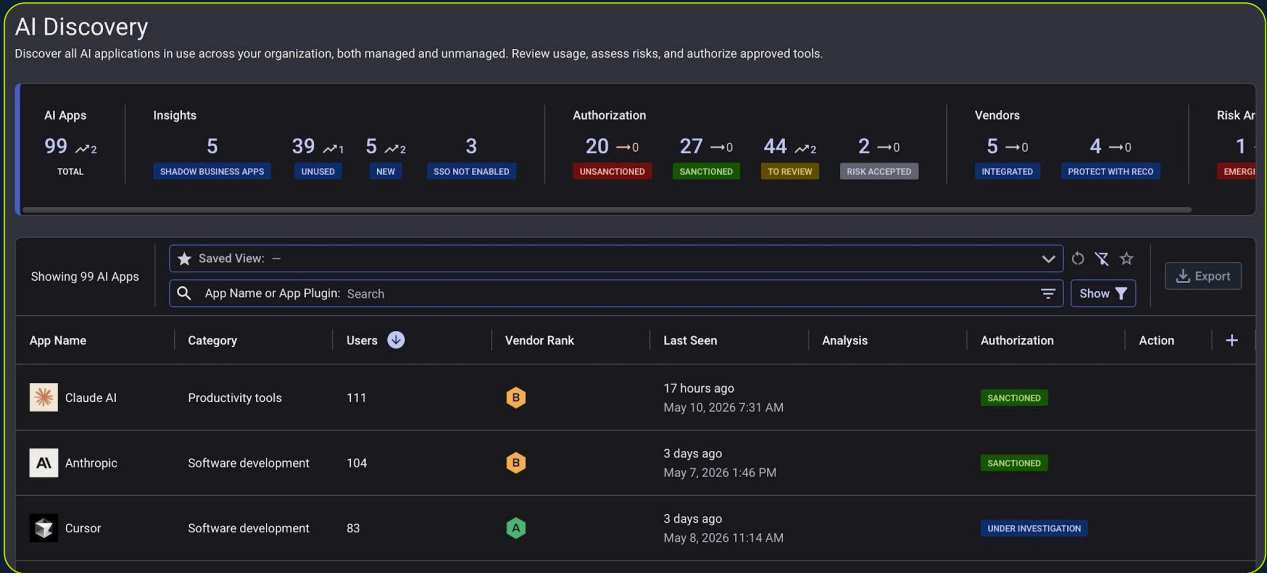


Figure 7: Reco's AI Discovery dashboard showing the full AI estate.

This visibility gives you a live source of truth for where agents operate, refreshed continuously as employees connect new tools. The gap measured in Findings 1 and 2 is an inventory problem first, and this closes it in hours rather than quarters.

Step 2: Map Identities and Permissions

For every agent identity, the Reco Graph maps which applications it connects to, which scopes it holds, who consented, and what data sits underneath, turning every identity, permission, and connection into one living map of risk.

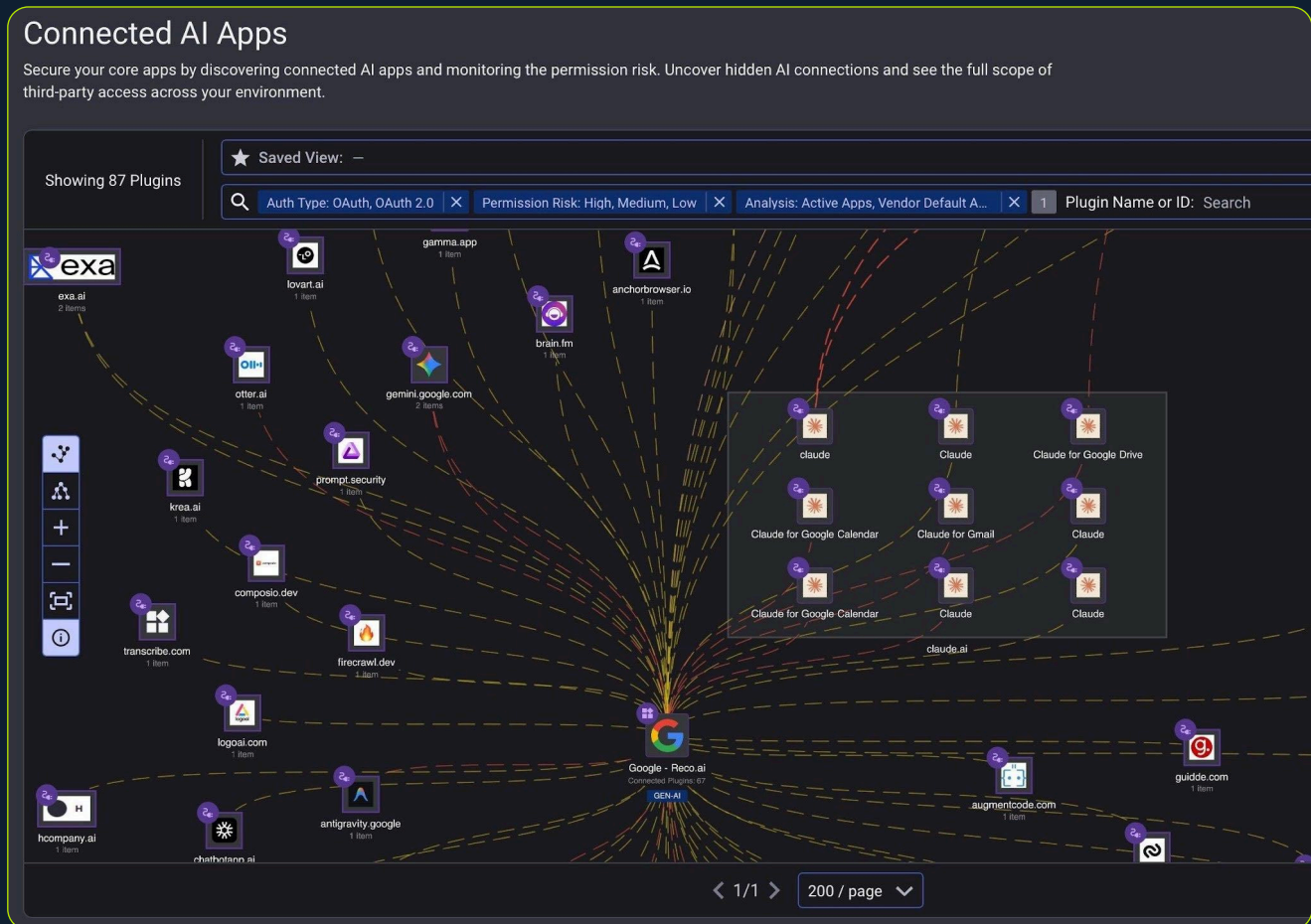


Figure 8: Reco Graph mapping AI connections and permissions.

This map is where the toxic combinations from Finding 4 surface automatically: the single identity bridging sensitive systems through OAuth grants, MCP servers, or API integrations that no single owner scoped together. It is the view no manual audit produces.

Step 3: Govern Tools, Agents, and Context

The agent inventory feeds identity and access governance. Every agent, MCP server, and embedded AI feature in the third-party ecosystem, sanctioned or not, is governed with the same primitives. Agent sprawl and unsanctioned MCP servers flow into the same loop as ordinary SaaS applications.

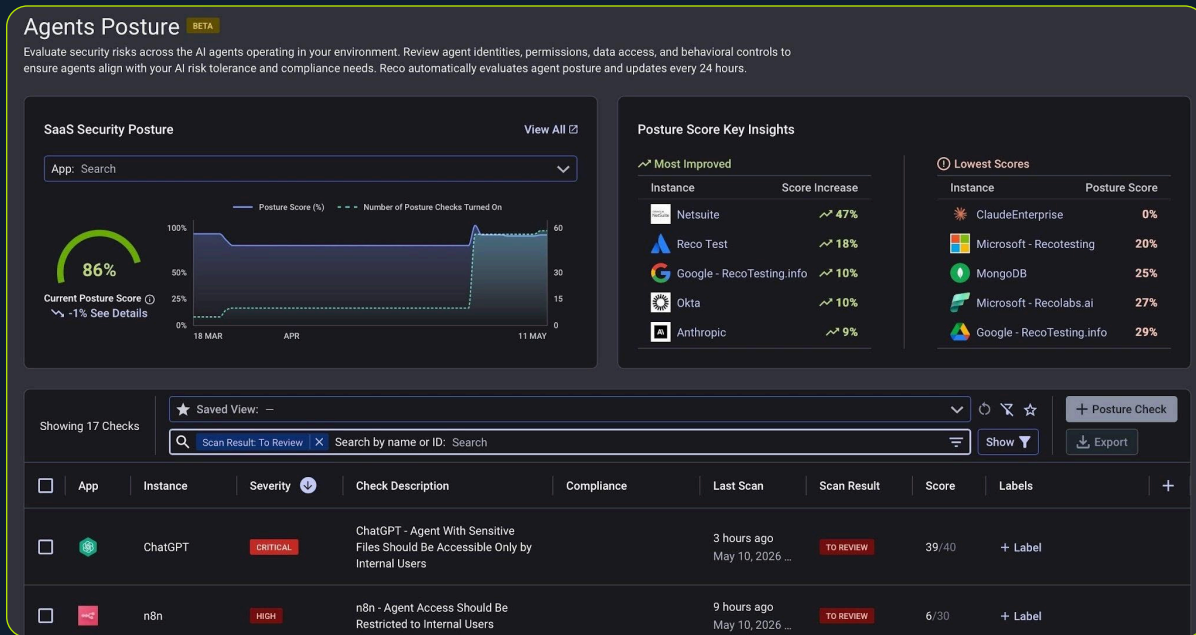


Figure 9: The agent posture dashboard scoring governance.

From there, Reco right-sizes access, which is the direct answer to Finding 3. You're able to strip powerful-by-default tools back to the scopes they actually use, so a compromised agent or session takes the smallest possible blast radius with it.

Step 4: Classify Data and Identity Risk

Reco classifies the data and identities behind each connection by sensitivity and risk. Sensitive data flowing to agents through connected apps or MCP servers is tagged against your data classification scheme, and the identities driving those flows are scored on privilege level and behavior history.

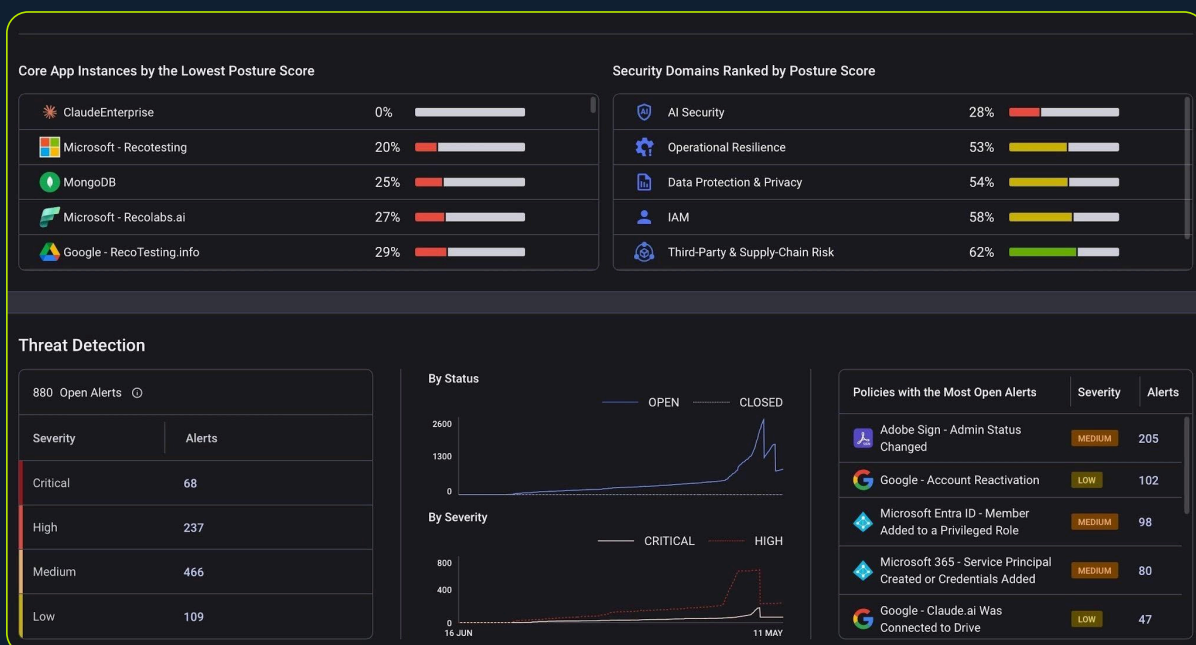


Figure 10: App instances ranked by posture score, alerts by severity.

Findings arrive tied to a specific data classification and identity context instead of as undifferentiated alerts, so the team prioritizes the connections that matter and treats the rest as expected business activity.

Step 5: Detect Exposure and Prove Control

Reco applies identity-centric behavioral analysis to agents the same way it does to human identities, separating normal automation from suspicious deviation in real time. When the next disclosure lands, the only question from Finding 5, "do we have it, and where," already has an answer, and the kill switch sits behind it. Revoke OAuth permissions, disable risky integrations automatically, and route the response to ServiceNow, Jira, or your SIEM.

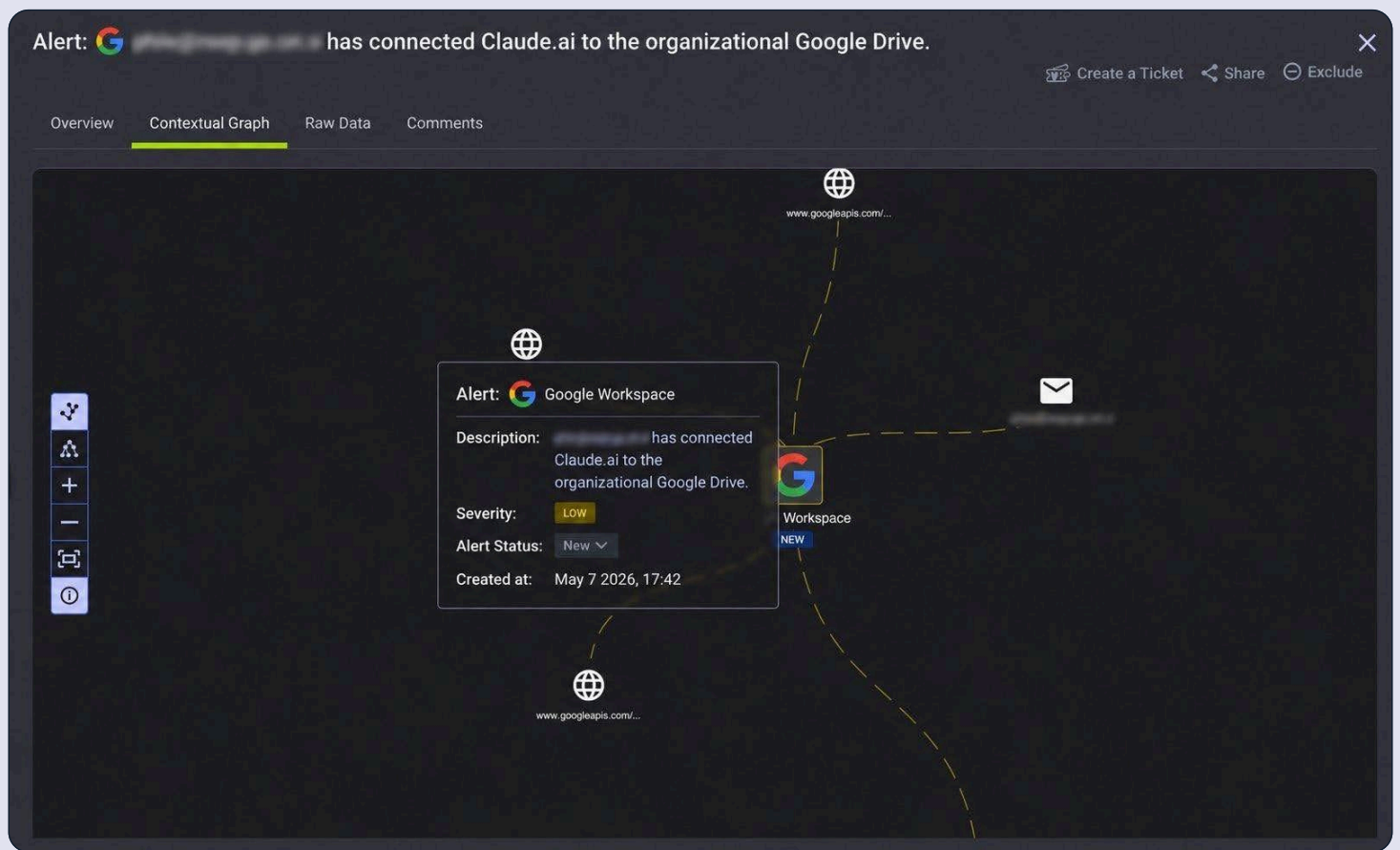


Figure 11: An alert on a new AI connection to the corporate drive.

When the audit lands instead, the evidence is already organized: agent inventory, permission maps, enforcement history, and identity exposure rendered against the same graph view.

The Choice Ahead

Unsanctioned AI was never going to go away. In a single year it picked up credentials, a marketplace, and autonomy, and it has already produced a one-click remote-code-execution vulnerability, tens of thousands of internet-exposed instances, and a supply chain seeded with poisoned skills.

The telemetry underneath is quieter and worse.

Most SaaS is authorized and catalogued, which looks like control, until you notice that unsanctioned AI saturates the smallest companies. Four in five AI tools run with nobody watching, and most of the agent tools we examined can reach straight into the host. Two in five carry the full kit at once; they can run commands, read and write files, and ship data off the machine.

The controls built for the application estate are blind to the identity layer where agents now operate.

You either map and govern the agent layer now, while it is still small enough to manage, or encounter it in the middle of an incident, when it is not. The tools for the first path already exist.



You can get started at [Reco AI](#).

[Request a Demo](#)

© 2026 Reco. All rights reserved. CONFIDENTIAL.